

AKFA Romix

Tizim Arxitekturası va Xavfsizlik Auditi **Baho: C-**

Executive Summary

AKFA Romix portalining dasturiy arxitekturası hozirgi holatda tezkor rivojlanish davrida yaratilgan monolitik va qisman tarqoq tizim hisoblanadi. Tizimda biznes funksionalligi juda yaxshi va to'g'ri loyihalashtirilgan, biroq arxitektura va axborot xavfsizligi jihatidan juda jiddiy xatolar mavjud.

Kritik Arxitekturaviy Kamchiliklar:

1. Server va Brauzer Chegaralarining Buzilishi ('bot.js' integratsiyasi)

Ushbu faylda Node.js backend kutubxonasi — 'telegraf' import qilingan va bot server-side rejimida ishga tushirilgan. Biroq, bu fayl brauzer bundle ichida joylashgan! Bu yig'ish (build) vaqtida yoki brauzerda ishga tushganda xatolik beradi.

```
import { Telegraf } from 'telegraf';
```

2. Maxfiy Kalitlar va Tokenlarning Ochiq Qolishi (Hardcoded Secrets)

Supabase Anon Key, Supabase URL va Telegram Bot Tokenlari kod ichida oddiy matn ko'rinishida yozilgan. Xakerlar yig'ilgan JS fayllaridan bu tokenlarni osonlikcha o'g'irlab olishi mumkin.

```
const BOT_TOKEN = '8876482426:AAFIMJCPYrxi-xVQ...';
```

3. Parollarni Hashlamasdan Solishtirish va Ochiq Saqlash

Tizimda foydalanuvchilar parollari bazada shifrlanmagan holda saqlanadi. Avtorizatsiya qilishda parollar SQL so'rovida to'g'ridan-to'g'ri tekshiriladi.

```
.eq('password', password)
```

Tavsiya Etiladigan Bosqichlar:

- **Bosqich 1:** Barcha maxfiy kalitlarni `.env` fayliga o'tkazish va Vite orqali yuklash.
- **Bosqich 2:** Telegram bot kodini alohida Node.js server rejimiga o'tkazish.
- **Bosqich 3:** Parollarni bcrypt orqali hashlab saqlash va JWT tekshiruvini yo'lga qo'yish.
- **Bosqich 4:** Monolitik `admin.js` va `hr.js` kodlarini kichik modullarga ajratish.